SECURITY

Supply Chain Security Visual Guide

Your code is 90% someone else's — secure the chain you build on.

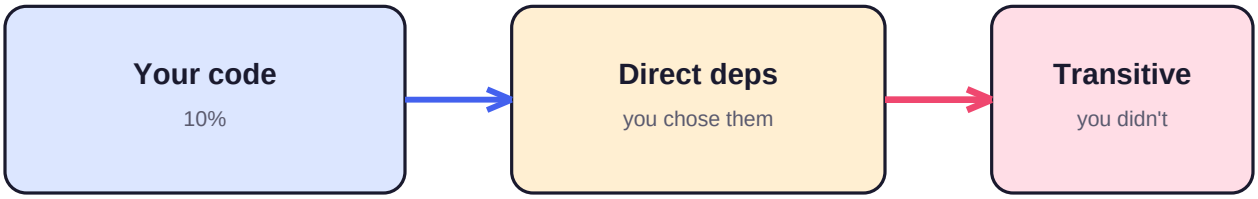
ANIMATED WALKTHROUGH

Step through pages to play the animation

STEP 1/6

The Dependency Reality

Every deploy inherits every dependency's risk.



Transitive dependencies are the blind spot — typosquats and compromised maintainers hide there. Visibility is step one.

STEP 2/6

SBOM: Know Your Ingredients

A software bill of materials for every artifact.

SBOM (CycloneDX / SPDX)

every component + version + license, machine-readable

- Generate the SBOM at build time — it must match what actually shipped.
- When a CVE drops, query SBOMs to find exposure in minutes, not weeks.
- Share SBOMs with customers; demand them from vendors.

STEP 3/6

Artifact Signing with Sigstore

Prove the artifact is really yours, keylessly.

Keyless signing ties the signature to the CI workload's identity — no long-lived keys to steal, and verifiers check a public transparency log.

STEP 4/6

Pinning & Lockfiles

Reproducible builds beat floating versions.

- Commit lockfiles — every build resolves the exact same dependency tree.
- Pin to hashes/digests for base images, not floating tags like 'latest'.
- Review dependency updates like code changes: diff, changelog, test.
- Automate updates (renovate/dependabot) but keep humans approving majors.

STEP 5/6

Provenance & SLSA

Attest HOW the artifact was built, not just what it is.

Provenance

Signed record: source commit, builder, build steps, materials.

SLSA levels

L1: provenance exists → L4: hermetic, reproducible builds.

A verifier can confirm: this binary came from this repo, built by this pipeline, from these inputs. Tampering anywhere breaks the chain.

STEP 6/6

Policy Gates

Make the pipeline enforce the rules.

- Admission: only signed artifacts with valid provenance may deploy.
- Block known-malicious packages and licenses via policy at pull time.
- Private registry proxy: vet once, serve internally — no direct public pulls in prod builds.
- Incident drill: practice the 'compromised dependency' response before it happens.

STEP ✓/✓

Key Takeaways

Supply Chain — Remember

- Your risk includes transitive dependencies you never chose — get visibility first.
- Ship an SBOM with every artifact; use it for instant CVE exposure checks.
- Sign artifacts keylessly (Sigstore) and record build provenance (SLSA).
- Pin versions, commit lockfiles, review dependency updates like code.
- Gate deploys on signatures + provenance; proxy public registries.
- Rehearse the compromised-dependency response before you need it.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev